April 2024

KUEHNE+NAGEL

Securing the Cloud

Principles, Patterns, and Tales from the Battlefield

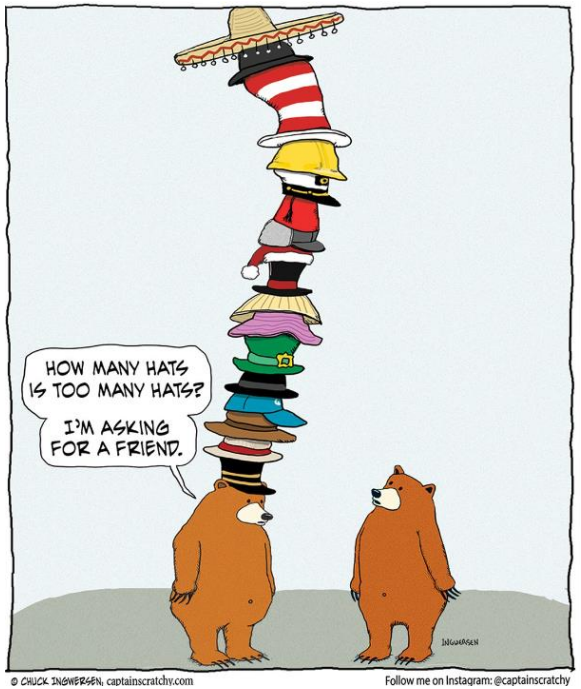


DevOps Community @ KN Porto IT Hub

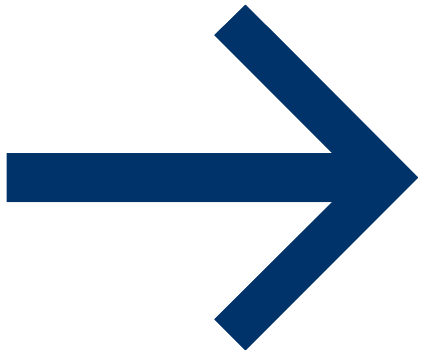
Hello

KUEHNE+NAGEL

- **João Pedro Dias**
- **Joined KN in April 2023, part of the MEP team @ KNITE+**
  - Software Engineer, also *acting* as Security Champion.
- **Life beyond KN:**
  - Invited Assistant Professor since 2017 @ Faculty of Engineering, Univ. Porto;
  - Ph.D. in Informatics Engineering focused in Software Engineering and IoT;
  - Interested in all things Software Engineering, Security, and Internet-of-Things;
  - Contributor to open-source & blog writter;
  - Semi-pro photographer (landscapes & nature, https://500px.com/jpdias);
  - Jack of all trades in my spare time: construction, woodworking, agriculture, ...
- **Where to find me?**
  - joao.dias@kuehne-nagel.com / jpdias@outlook.com / jpdias@pm.me
  - https://jpdias.me



KUEHNE+NAGEL



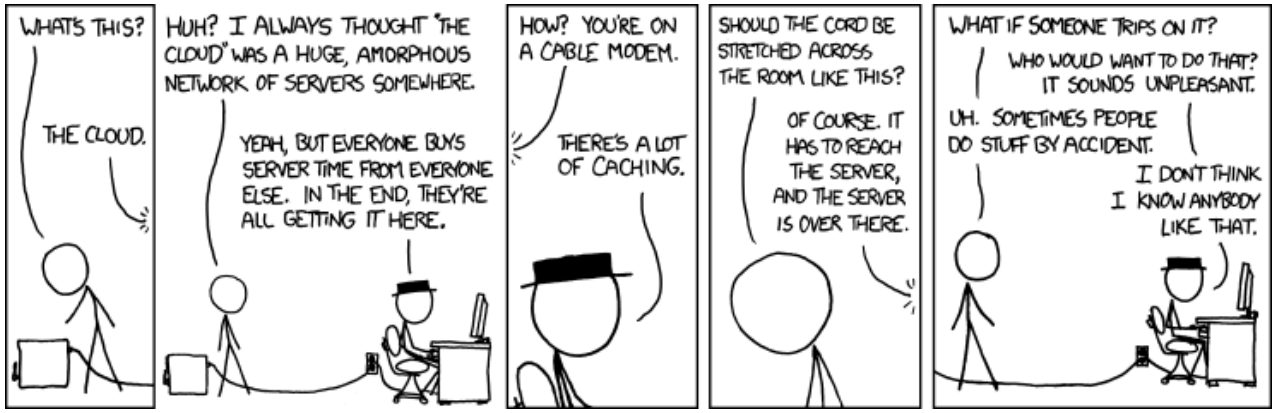
Index

1. Defining ☁ and ☁+🔐
2. (Opinionated) Principles & Patterns
3. Tales from the Battlefield
4. What’s next?

Defining

KUEHNE+NAGEL

- Databases, applications, and other resources on-demand with fast provisioning
- Pay-as-you-go pricing model
- Easy scaling as you go
- High availability (redudancy) and global coverage (regions)

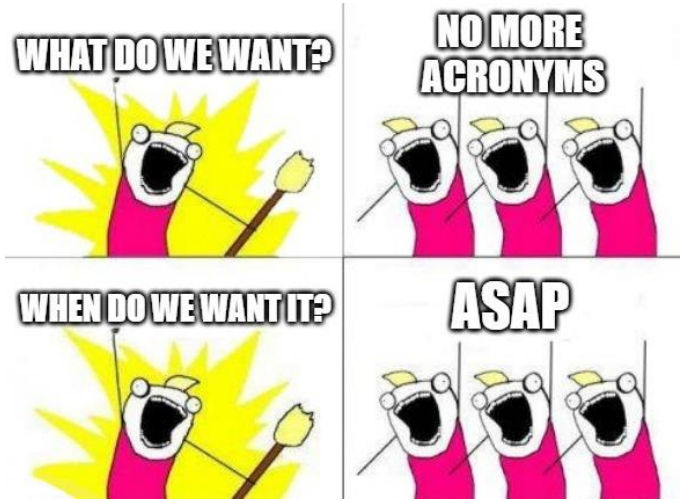


From *xkcd*, https://xkcd.com/908/

Defining ☁+🔐

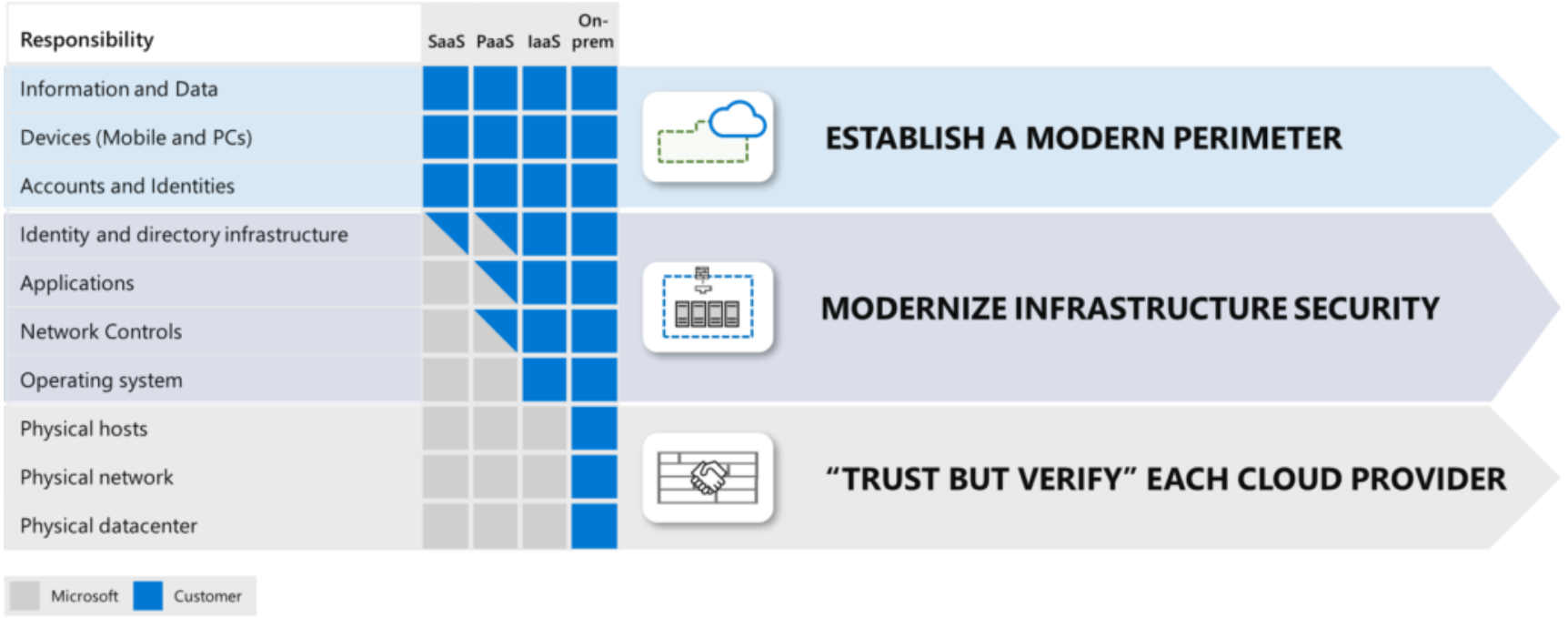
KUEHNE+NAGEL

- **CSPM – Cloud Security Posture Management**
  - KSPM – Kubernetes Security Posture Management
  - DSPM – Data Security Posture Management
- **DLP – Data Loss Prevention**
- **CIEM – Cloud Infrastructure Entitlement Management**
- **IAM – Identity and Access Management**
- **CWPP – Cloud Workload Protection Platform**
- **CNAPP – Cloud Native Application Protection Platform**
- **CDR – Cloud Detection and Response**
- **SIEM – Security Information and Event Management**
- **SOC – Security Operations Center**



Defining ☁+🔐 : *Not a silver bullet*

KUEHNE+NAGEL



From *Shared responsibility in the cloud*,
https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility

Defining ☁ + 🔐

KUEHNE+NAGEL

ramimac/**aws-customer-security-incidents**

A repository of breaches of AWS customers



4 Contributors
11 Issues
634 Stars
37 Forks



Defining ☁ + 🔐

KUEHNE+NAGEL

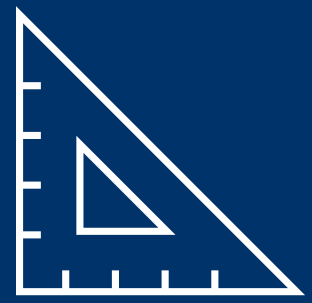
Threat	Initial Access	Cloud-specific	Impact
Static API Credential Exposure to Account Hijack	Yes	Yes	High
Compromised Server via Exposed Remote Access Ports	Yes	Yes	High
Compromised Database via Inadvertent Exposure	Yes	Yes	High
Object Storage Public Data Exposure	Yes	Yes	High
Server Side Request Forgery	Yes	No	High
Cryptomining	No	~	Medium
Network Attack	Yes	No	High
Compromised Secrets	No	No	Low
Novel Cloud Data Exposure and Exfiltration	Yes	Yes	High
Subdomain Takeover	Yes	~	Medium

From *Learning from AWS Customer Security Incidents [2022]*, https://speakerdeck.com/ramimac/learning-from-aws-customer-security-incidents-2022

KUEHNE+NAGEL

Rules to Live By

(Opinionated) Principles & Patterns



Keeping (yourself) up-to-date

KUEHNE+NAGEL

- **Join RSS feeds for CVEs**
  - https://aws.amazon.com/security/security-bulletins/
  - https://cloud.google.com/support/bulletins
  - …
- **Threat intelligence and news feeds**
  - https://www.nist.gov/blogs/cybersecurity-insights
  - https://blog.talosintelligence.com/
  - https://krebsonsecurity.com/
  - https://www.crowdstrike.com/blog/category/threat-intel-research/
  - https://github.com/muchdogesec/awesome-threat-intel-blogs
  - …
- **Join your local infosec gatherings/meetups**

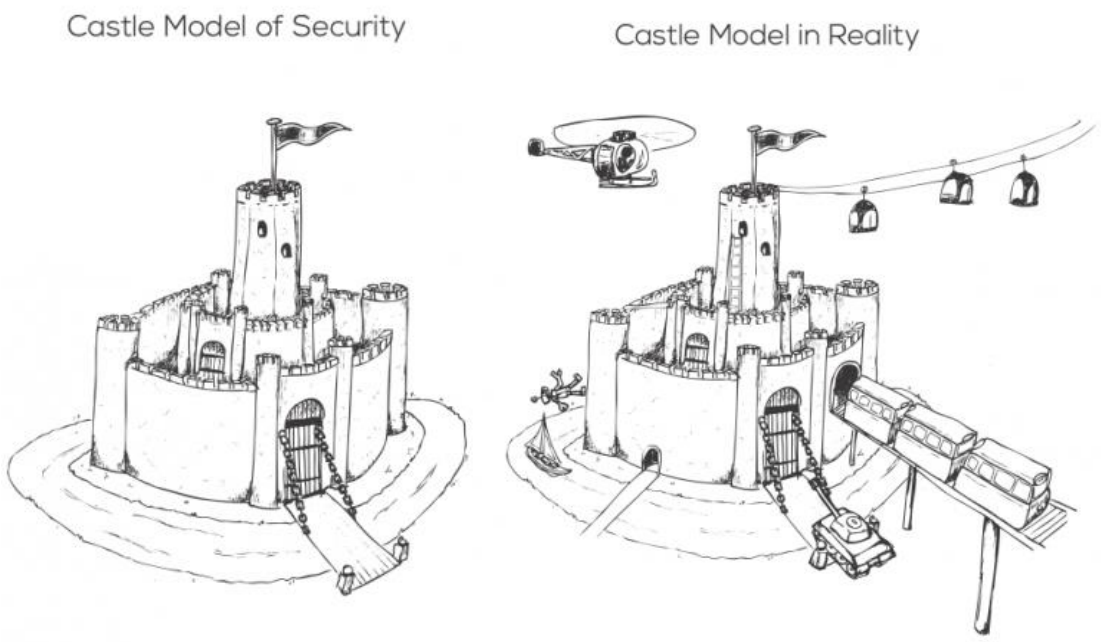


0XOPOSEC CØNFRAR1A Lisbon BSIDES

Protect your network

KUEHNE+NAGEL

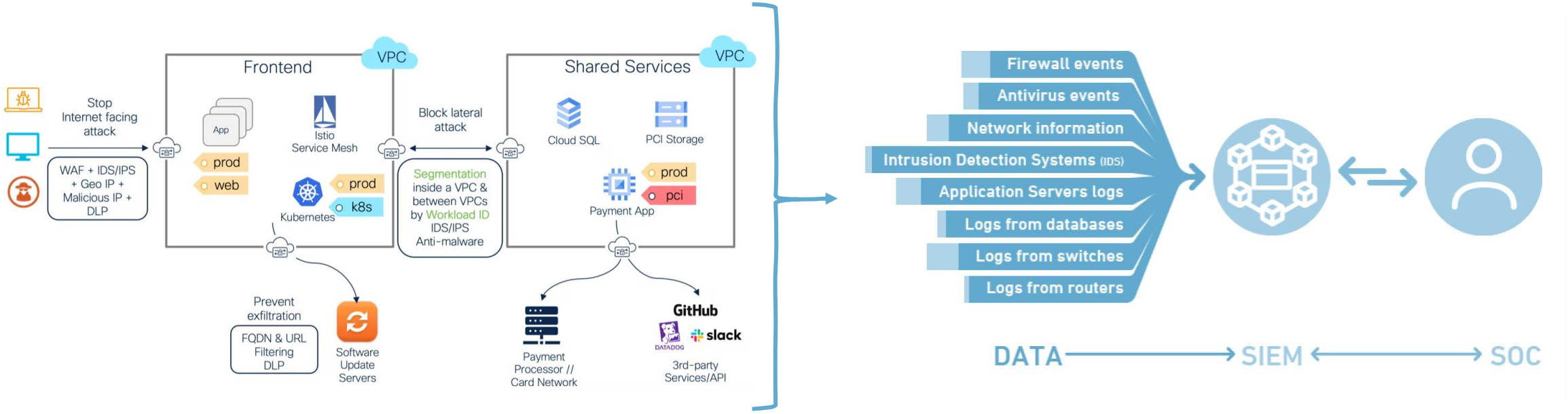
- **Deploy zero-trust networks**
- **Secure internet-facing services**
- **Secure connections between all environments**
  - Include on-premises or multi-cloud
- **Micro-segment access**
  - Secure your perimeter
  - Bulkhead pattern for blast-radius containment
- **Disable default networks and accesses**
- **Inspect and monitor your network traffic**
  - IDS + IPS + Egress&Ingress Proxy
  - Darktrace or similar (anomaly detection)
- **Keep track of your network configuration and assets**



From *Beyond the Castle Model of cyber-risk and cyber-security*, https://www.serene-risc.ca/en/digest/are-we-thinking-about-security-the-right-way-or-are-we-just-building-castles-in-the-sky

Protect your network

KUEHNE+NAGEL

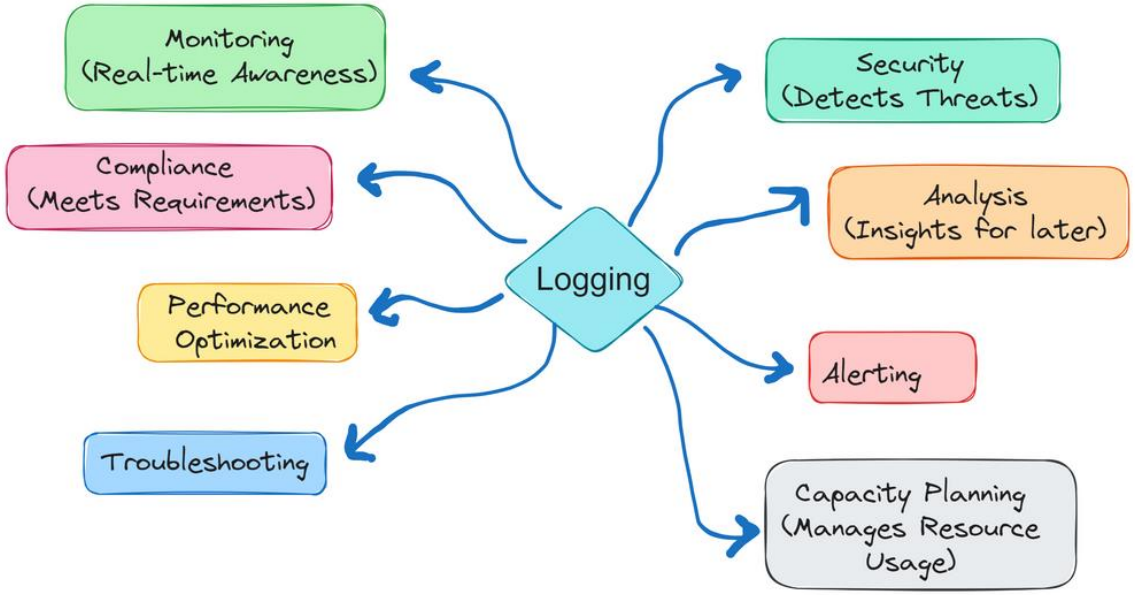


From *Multicloud security: architecture and ultimate guide*,
https://www.cisco.com/site/us/en/learn/topics/security/multicloud-security-architecture.html

Audit and monitor

KUEHNE+NAGEL

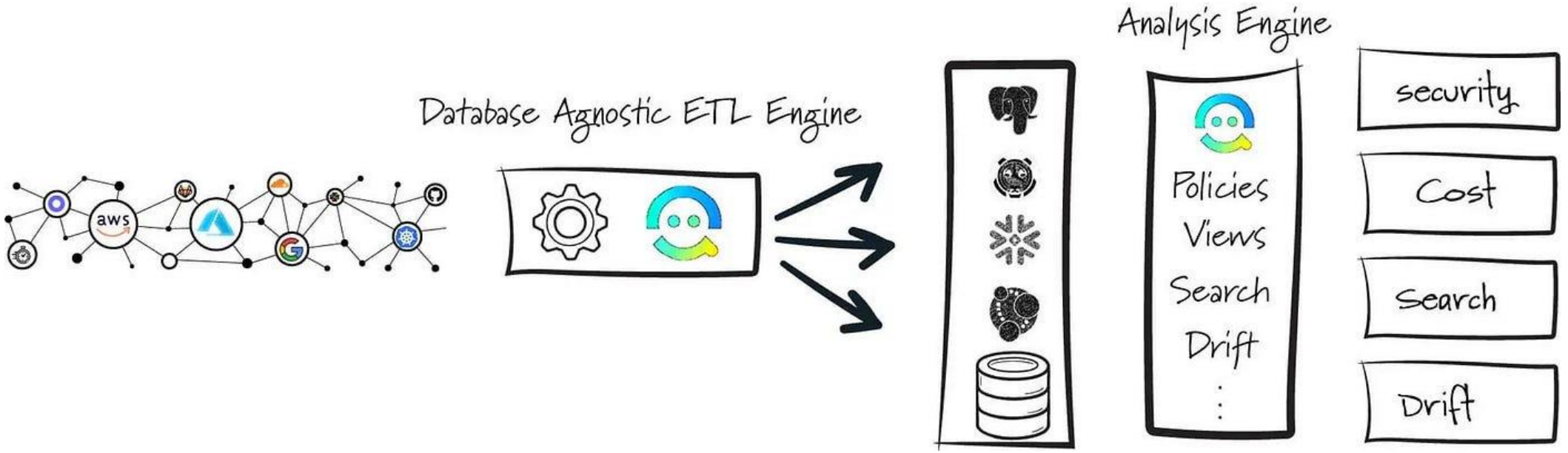
- **Continuous compliance**
- **Security checklist *is not* security in practice**
- **Centralize your monitoring**
- **Avoid alert fatigue (alert wisely and prioritize)**
- **Define processes for alerts**
- **Provide context (for alerts and monitors)**
- **Ensure complete coverage from build to runtime**
- **Carry periodic manual inspections**



From *Enhancing System Security with Advanced Logging and Auditing in Linux*, https://www.atatus.com/blog/logging-and-auditing-in-linux/

Keep an asset inventory

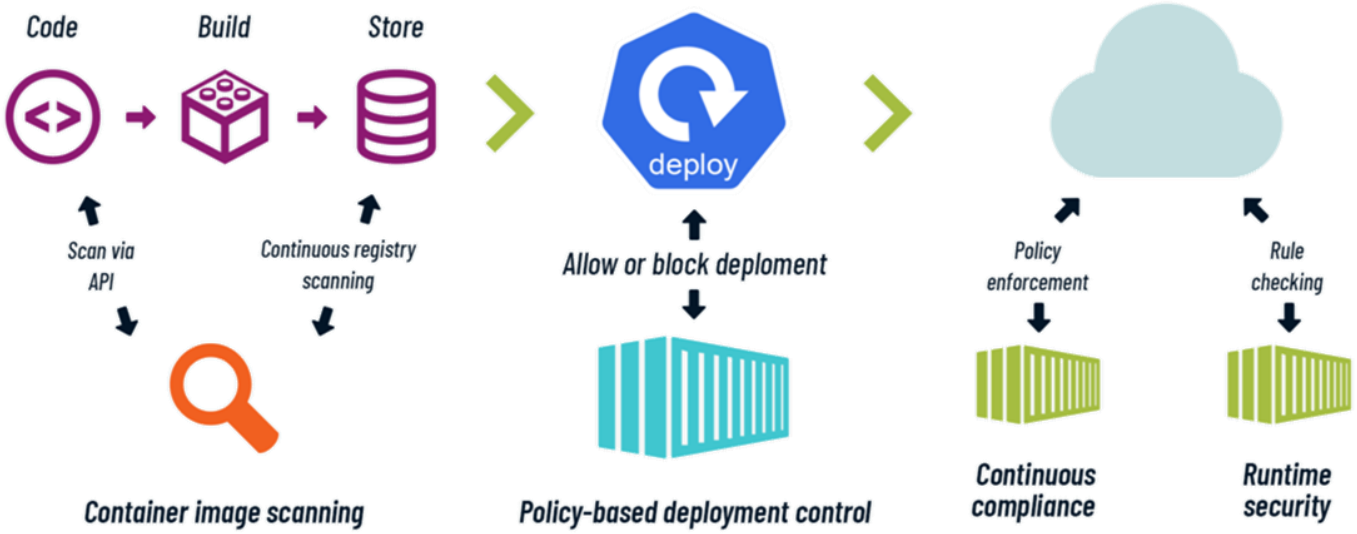
KUEHNE+NAGEL



From *CloudQuery with Grafana dashboards*,
https://medium.com/@ozbillwang/cloudquery-with-grafana-dashboards-ea058af2228

Protect your machine images

KUEHNE+NAGEL



aqua trivy

+

Open Policy Agent

+

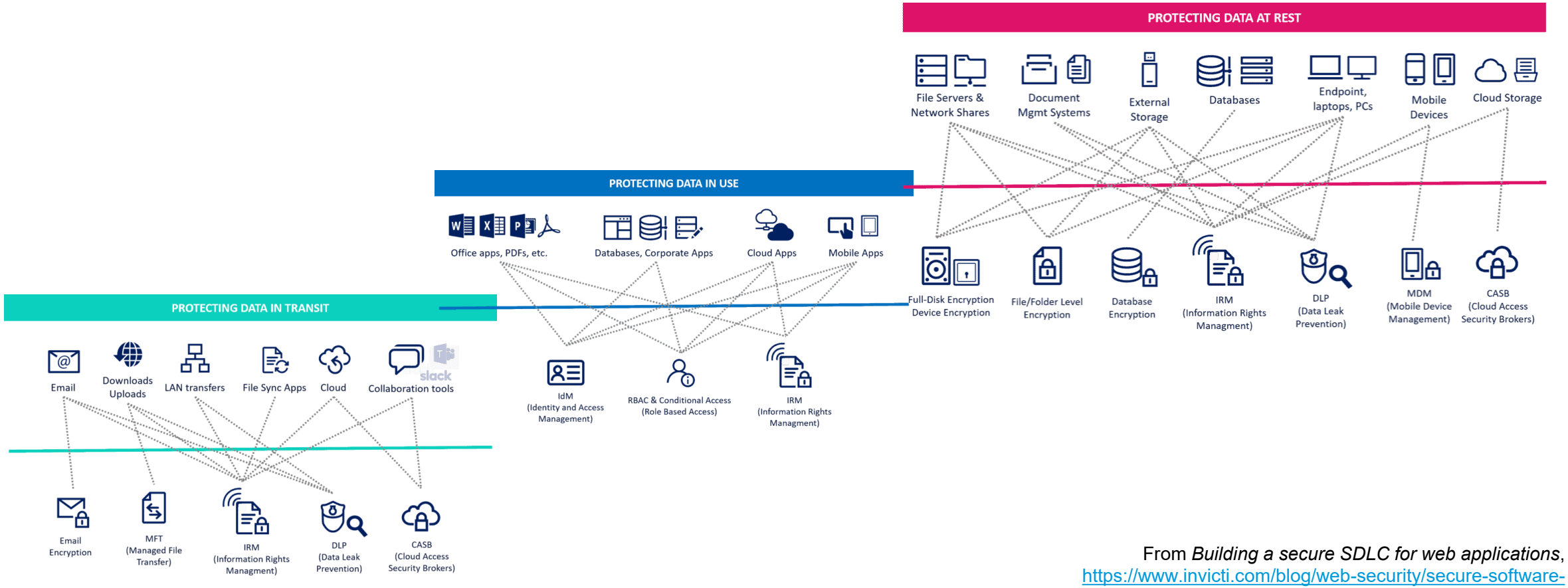
eBPF

StackRox

From *What is Container Security?*,
https://cloudone.trendmicro.com/docs/container-security/about/

Protect your data (in transit, in use and at rest)

KUEHNE+NAGEL

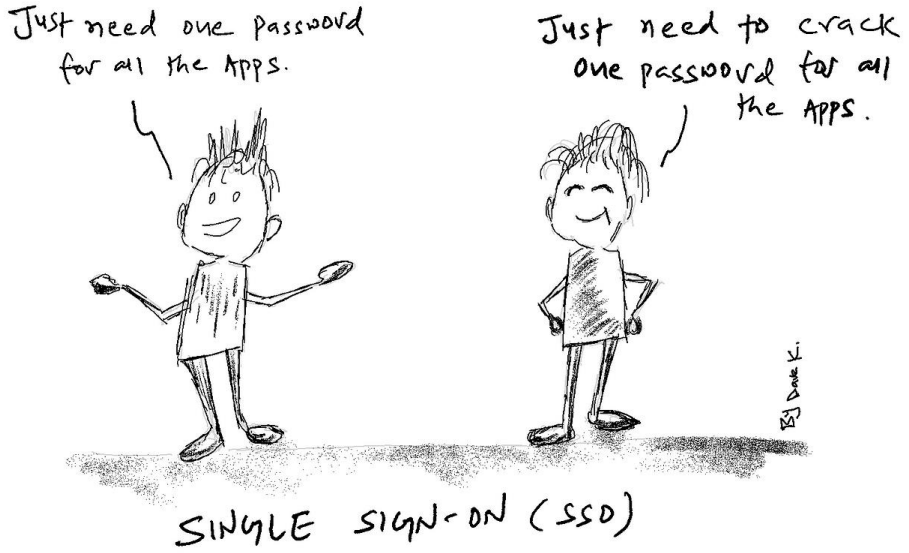


From *Building a secure SDLC for web applications*, https://www.invicti.com/blog/web-security/secure-software-development-lifecycle-ssdlc-web-applications/

Access Control and Least Privilege

KUEHNE+NAGEL

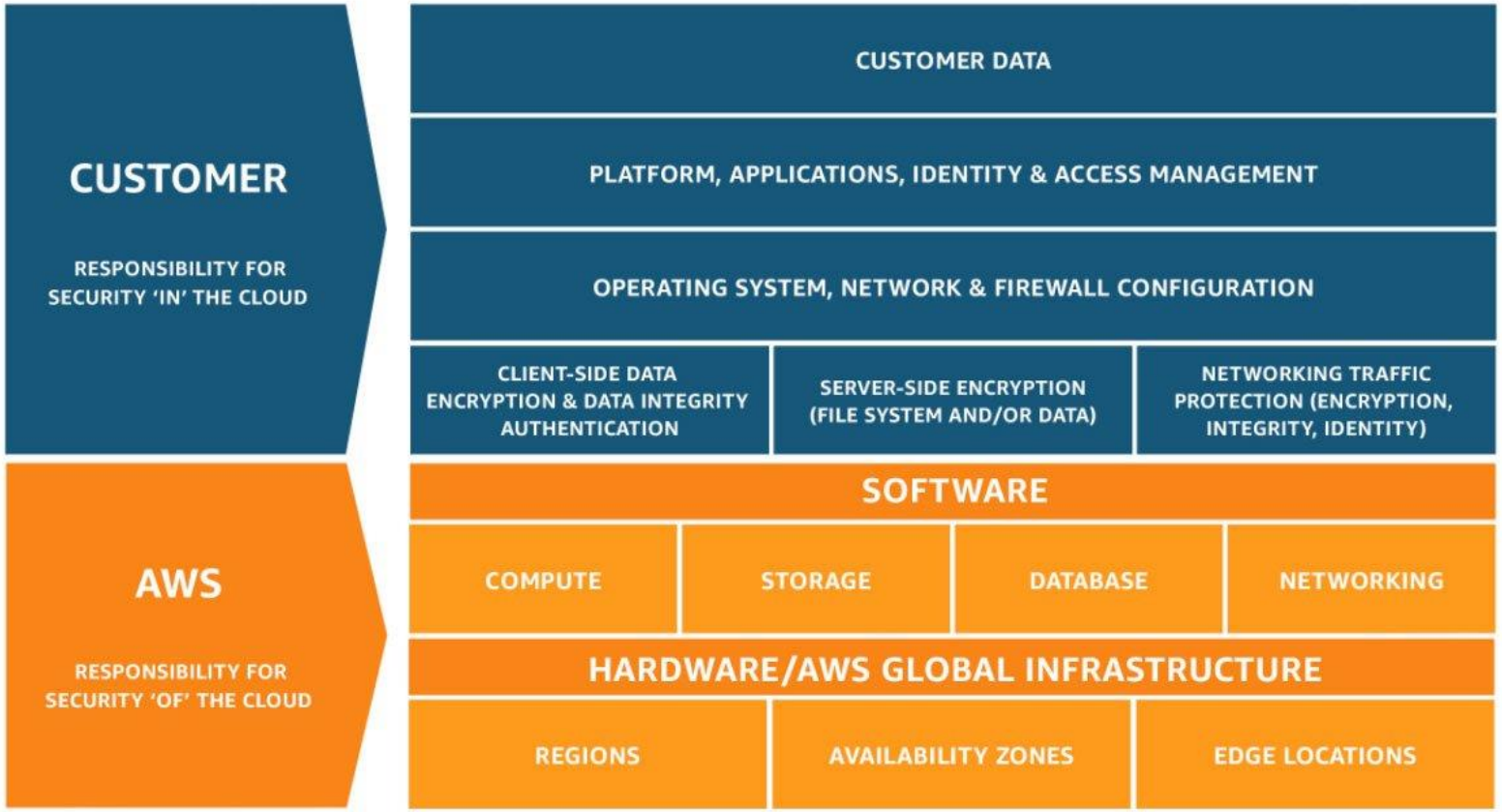
- **Use a single identity provider:**
  - Set up federated identity system / SSO
  - Use and enforce strong Multi-Factor Auth
  - *Avoid SMS tokens as MFA*
  - Keep your MFA seeds safe
    - ⚠ *G. Authenticator syncs seeds to the cloud*
- **Protect the super admin account**
- **Plan your use of service accounts**
- **Implement least privilege and separation of duties**
- **Set up audit access**
- **Automate your policy controls**
- **Set restrictions on resources**
- **Use temporary accesses (Valet Key pattern):**
  - Set up expiry dates on tokens and certificates



From *Single Sign-on (SSO)— Two Sides Of One Coin*, https://daveoncyber.medium.com/single-sign-on-two-sides-of-one-coin-cybersketch-fd35e7d4de0d

Know your responsibility

KUEHNE+NAGEL

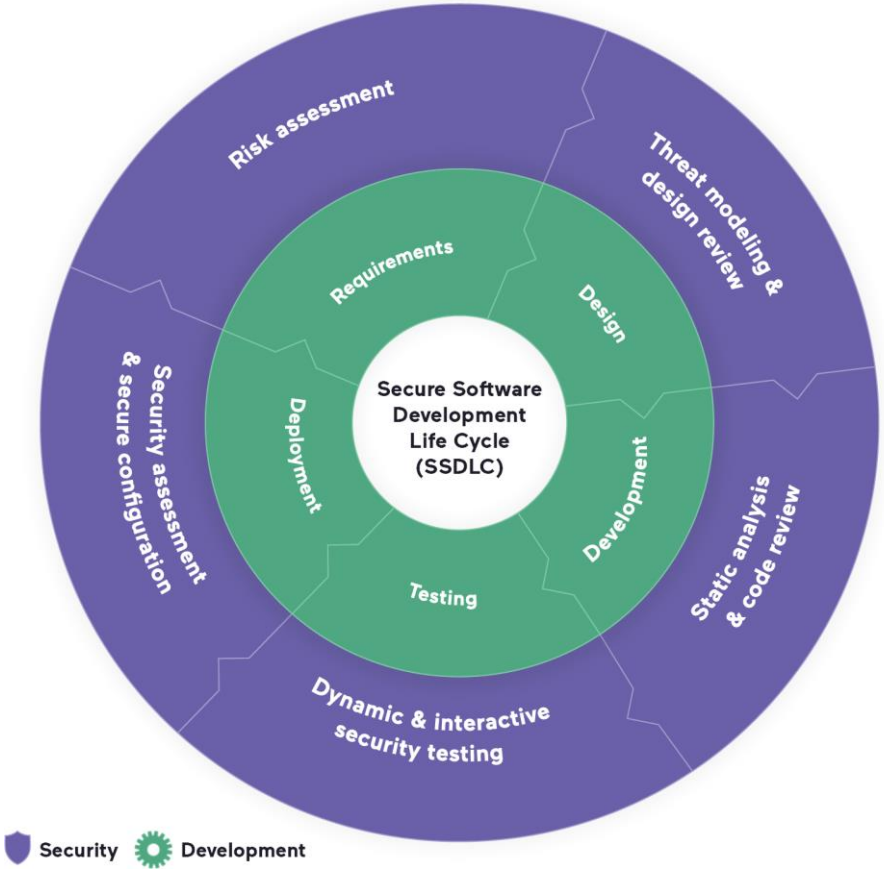


From AWS, *The Shared Responsibility Model*, https://docs.aws.amazon.com/whitepapers/latest/applying-security-practices-to-network-workload-for-csps/the-shared-responsibility-model.html

Protect applications

KUEHNE+NAGEL

- **SSDLC ≈ DevSecOps**
- **OWASP Top-10's**
  - API
  - Web
  - IoT
  - Desktop App Security
- **Use static and dynamic application security testing tools**
- **Have proper observability / telemetry**
- **Quarantine pattern**
  - External assets meet a team-agreed quality level before being authorized to be used.
- **Set up throttling**
  - Leaky bucket pattern
- **Decouple *critical* components (publish/subscribe)**

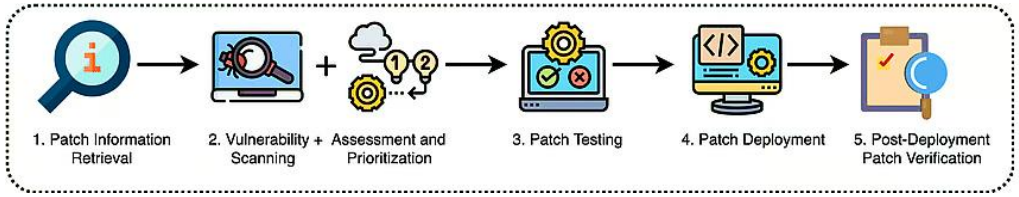


From *Building a secure SDLC for web applications*, https://www.invicti.com/blog/web-security/secure-software-development-lifecycle-ssdlc-web-applications/

Keep software patched

KUEHNE+NAGEL

- **Vulnerability management**
  - Software bills of materials (SBOMs)
  - Only use trusted dependencies
- **Patching intelligently (regularly *not* instantly)**
  - Avoid *latest version* by default
  - As reference, "*All DoD information systems have current patches within **21 days** of IAVA patch release (US-CERT).*"
- **Be aware of impact**
  - CVSS scores as information source
  - Mitigate risks when patching is not available



From *Dissanayake, Nesara & Zahedi, Mansooreh & Jayatilaka, Asangi & Ali Babar, Muhammad. (2022). Why, How and Where of Delays in Software Security Patch Management: An Empirical Investigation in the Healthcare Sector*

Detection engineering / threat hunting

KUEHNE+NAGEL

- **Data collections**
  - Indices of Compromise (IoC)
  - Indicators of Attack (IoA)
  - Techniques, tactics and procedures (TTPs)
- **Rule and signature scan / development**
- **Behaviour analytics and heuristics**
- **Identify gaps**
- **Emulate adversaries**



Threat Hunting Maturity Model Cycle

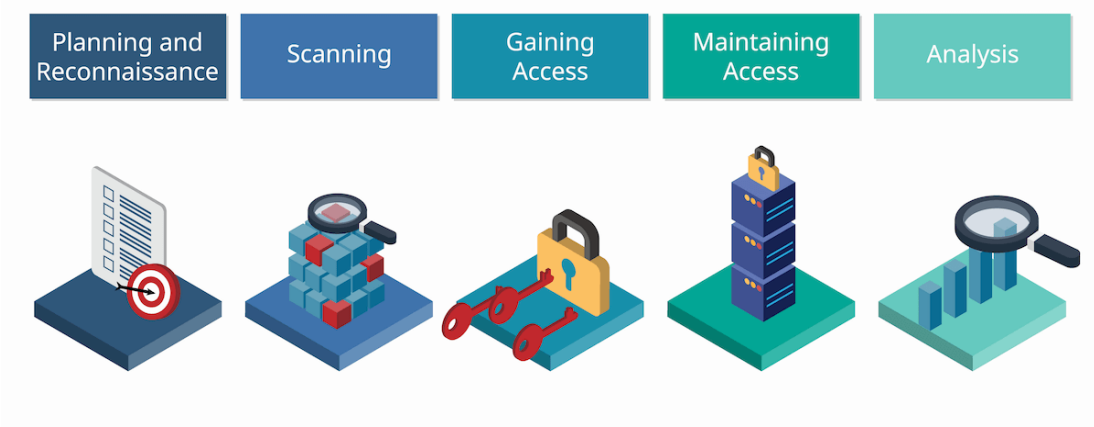
From *Introducing the Threat Hunting Maturity Model*, https://www.dts-solution.com/a-threat-hunt-tale/

Adversary simulation trials and readiness checks

KUEHNE+NAGEL

“the proof of the pudding is in the eating”

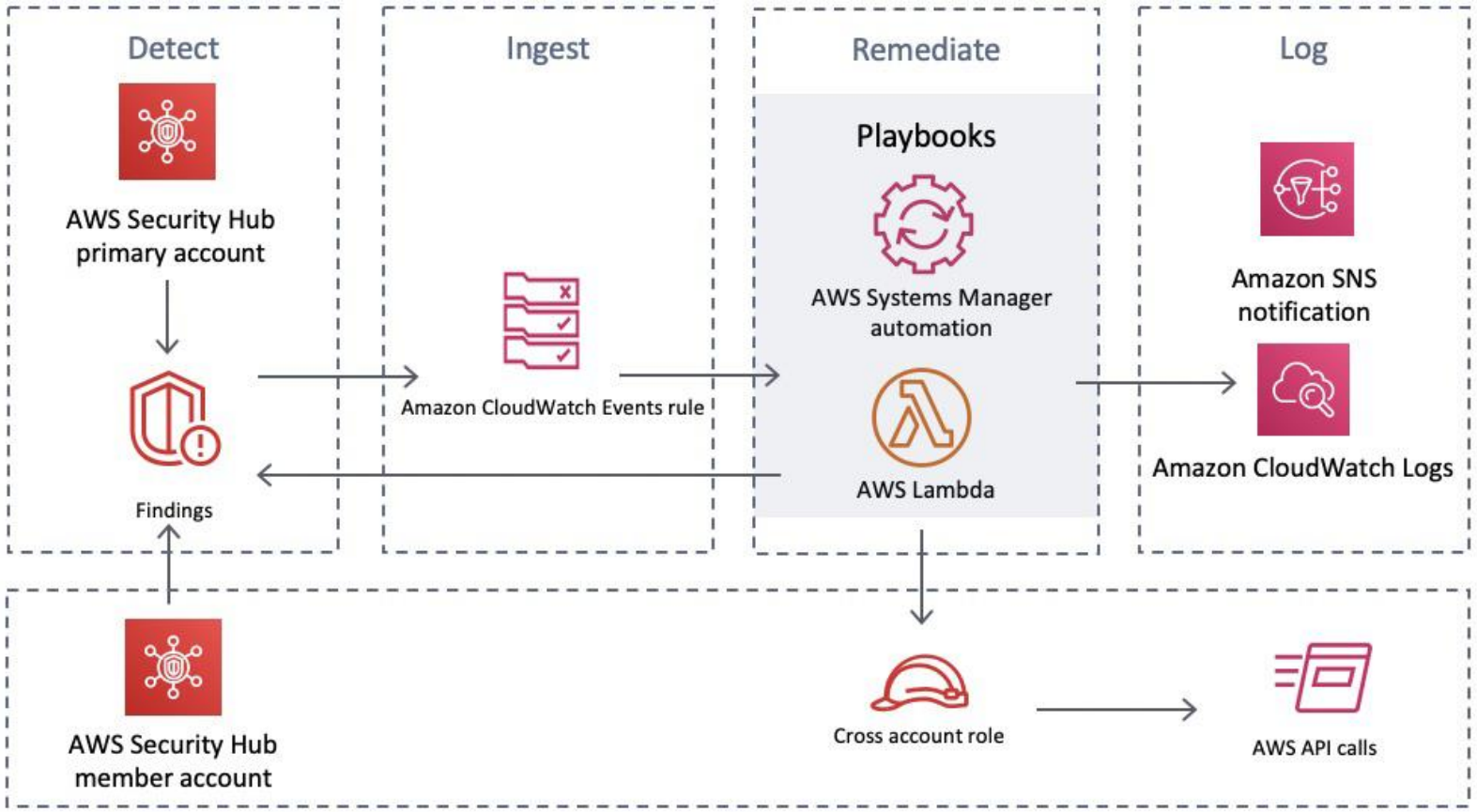
- **Ongoing automated tests**
  - AWS CloudSaga
- **Deception Engineering**
  - Honeypots
  - Canary Tokens
  - Tarpits



From *Penetration Testing Phases: A Roadmap To Secure Enterprise Applications*, https://successive.cloud/penetration-testing-phases/

Automate!

KUEHNE+NAGEL

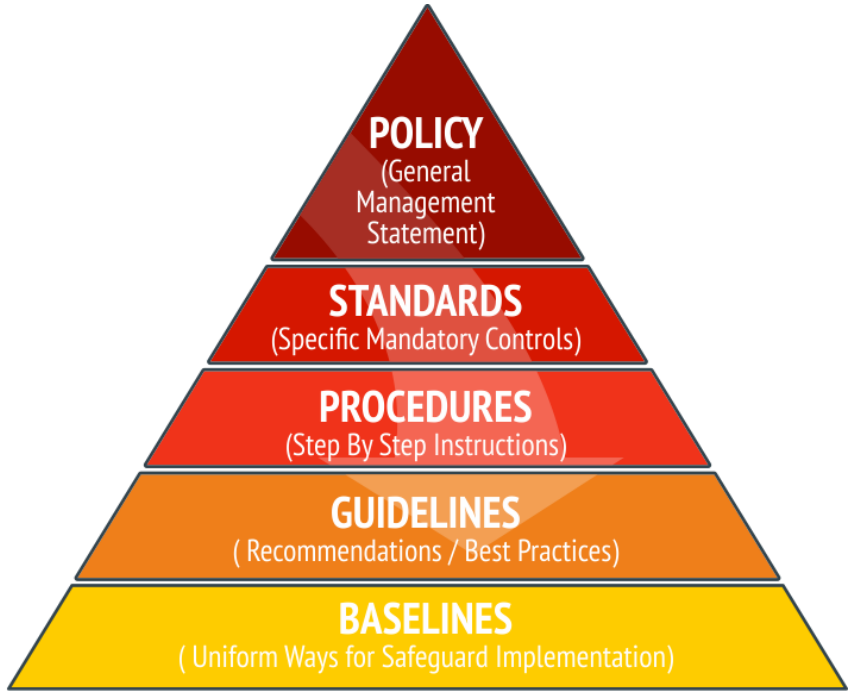


From *How to deploy the AWS Solution for Security Hub Automated Response and Remediation*, https://aws.amazon.com/blogs/security/how-to-deploy-the-aws-solution-for-security-hub-automated-response-and-remediation/

Define security policies, standards, and procedures

KUEHNE+NAGEL

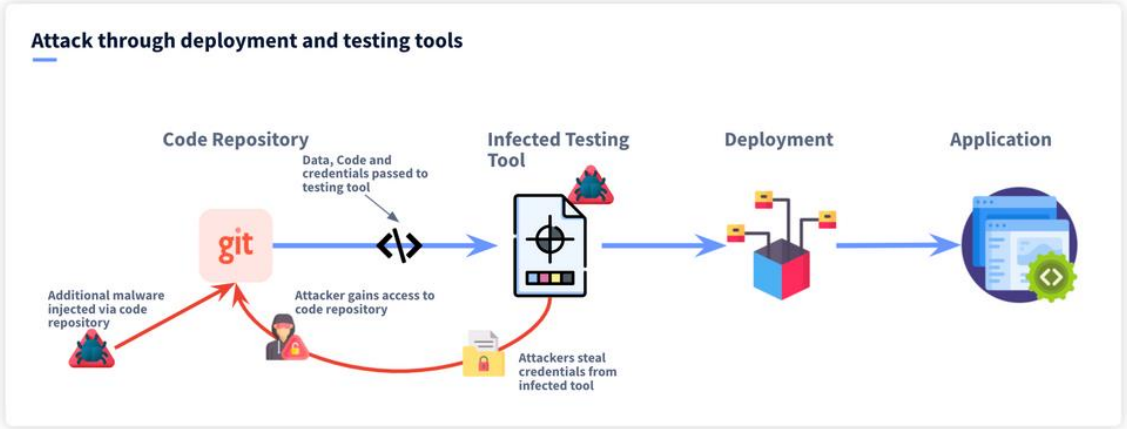
- Outline governance structure and compliance requirements
- Risk Assessment and Management
- Define a Security Architecture
- Access Control and Identity Management
- Data Encryption and Protection
- Incident Response and Management
- Third-Party Risk Management
- Monitoring and Auditing
- Employee Training and Awareness

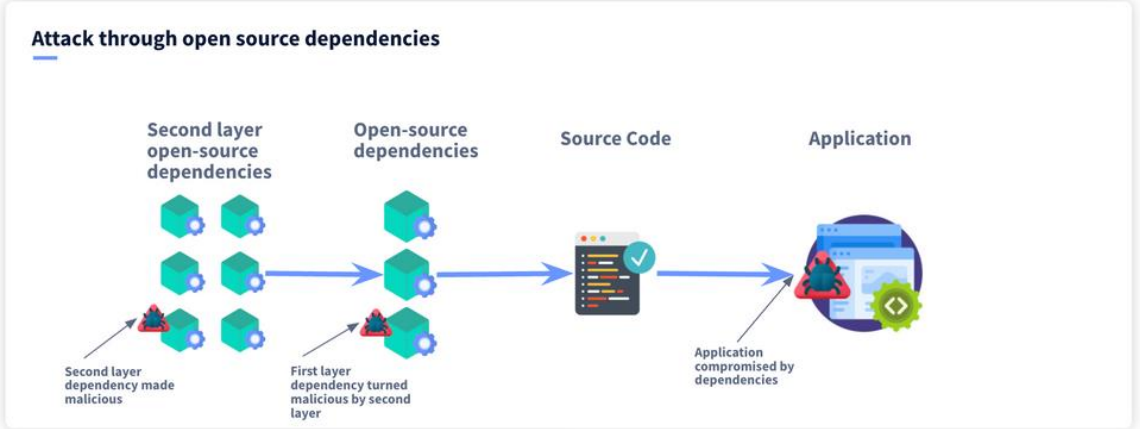


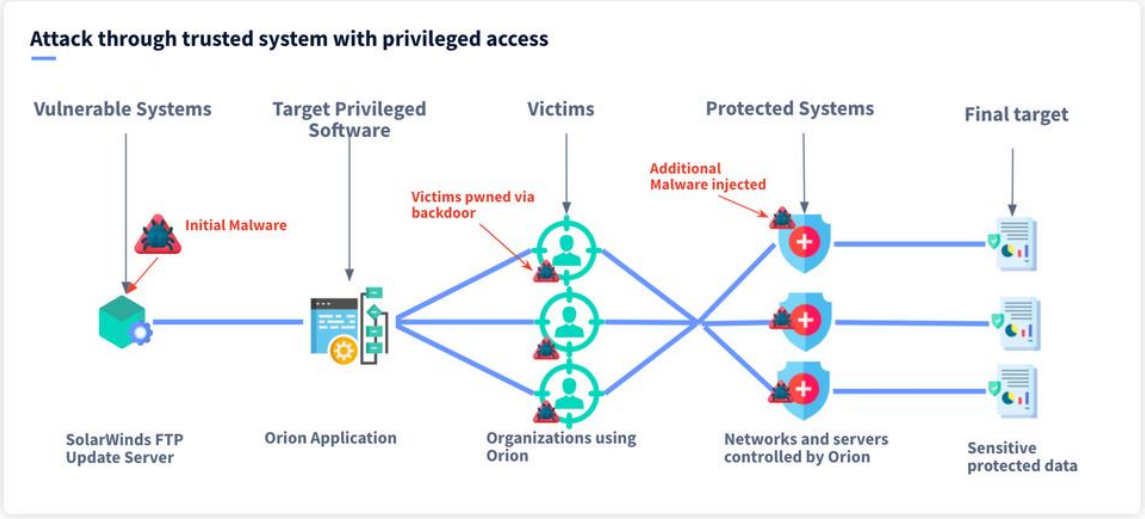
From *Develop Policies for an All-round Approach to Information Security*, https://www.7sec.com/blog/develop-policies-for-an-all-round-approach-to-information-security/

Be aware of your supply chain

KUEHNE+NAGEL



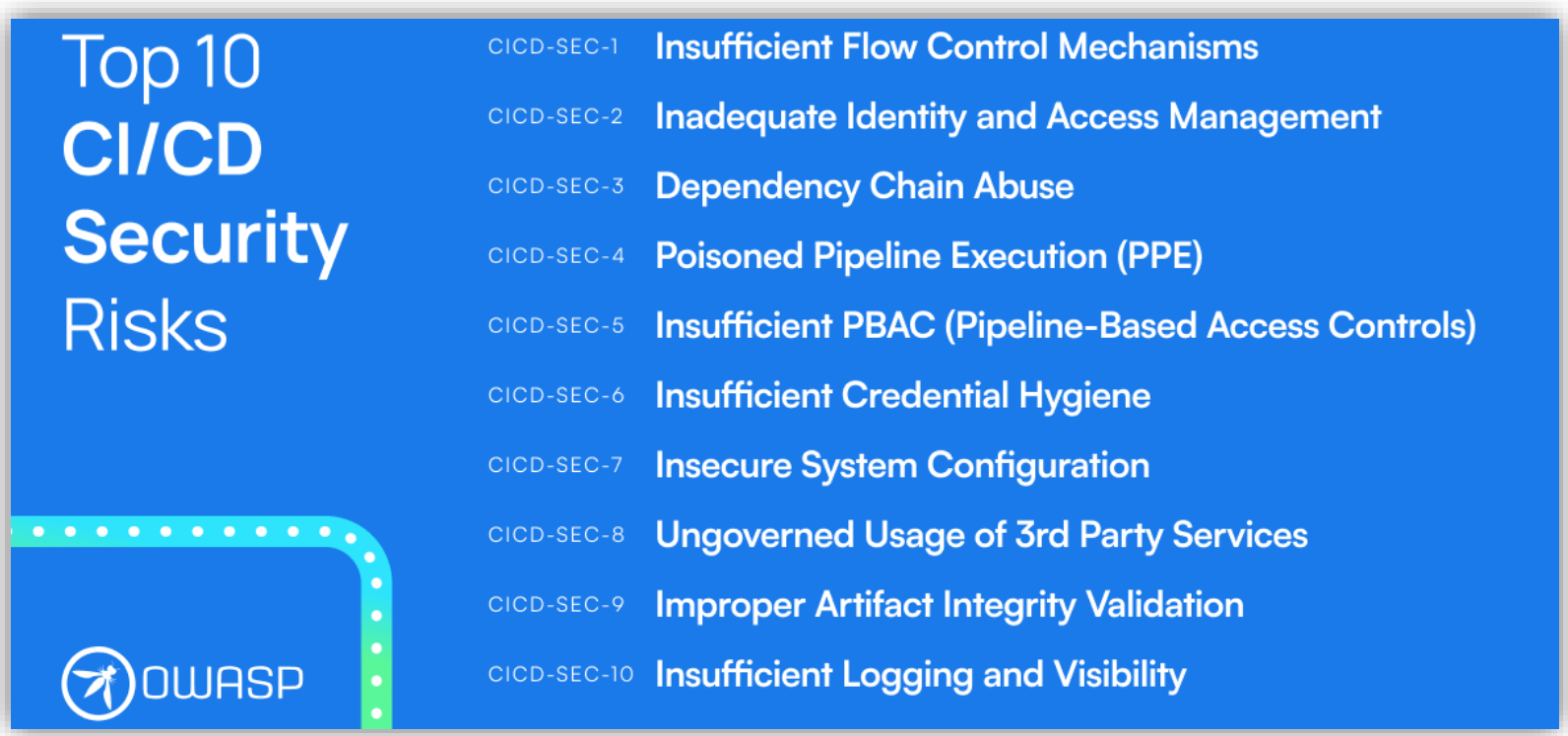




From *Supply Chain Attacks: 6 Steps to protect your software supply chain*, https://blog.gitguardian.com/supply-chain-attack-6-steps-to-harden-your-supply-chain/

Secure your pipelines

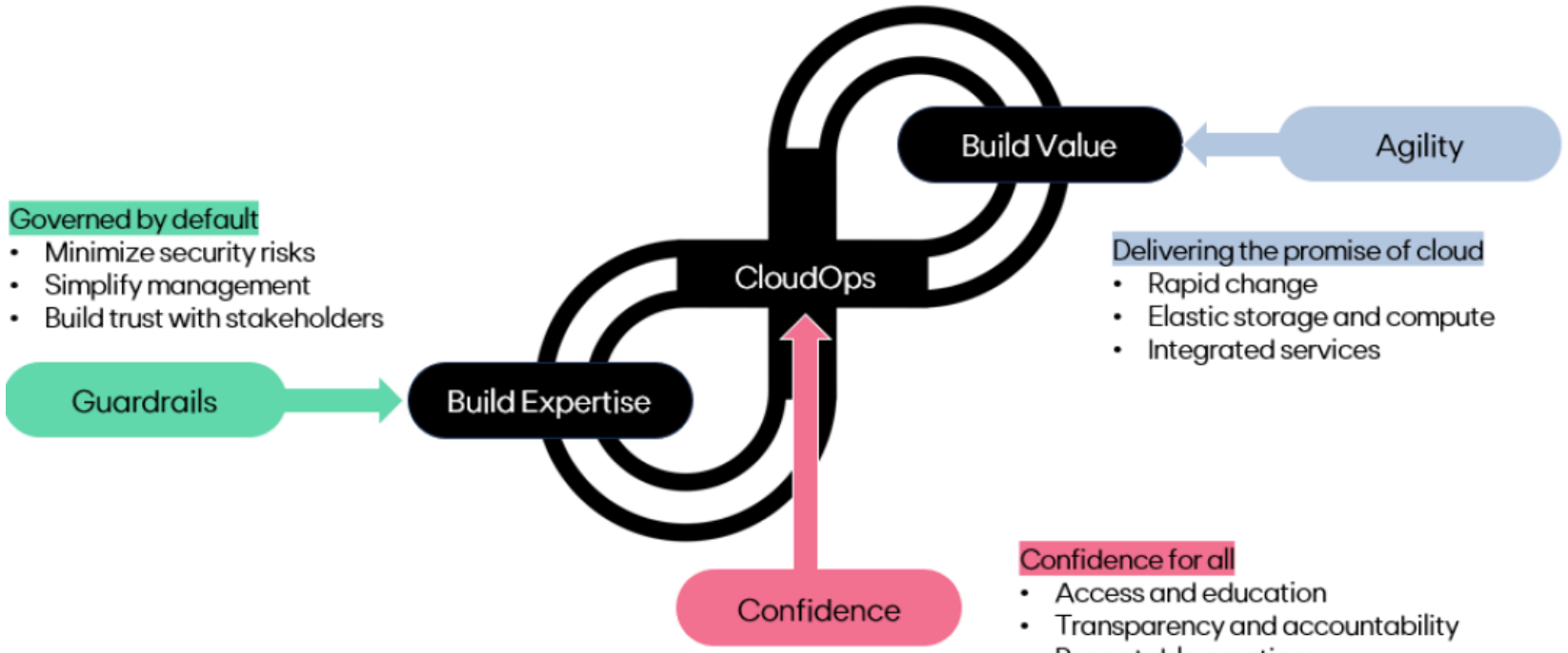
KUEHNE+NAGEL



From *Top 10 CI/CD Security Risks*,
https://github.com/cider-security-research/top-10-cicd-security-risks

Guardrails not gatekeepers

KUEHNE+NAGEL

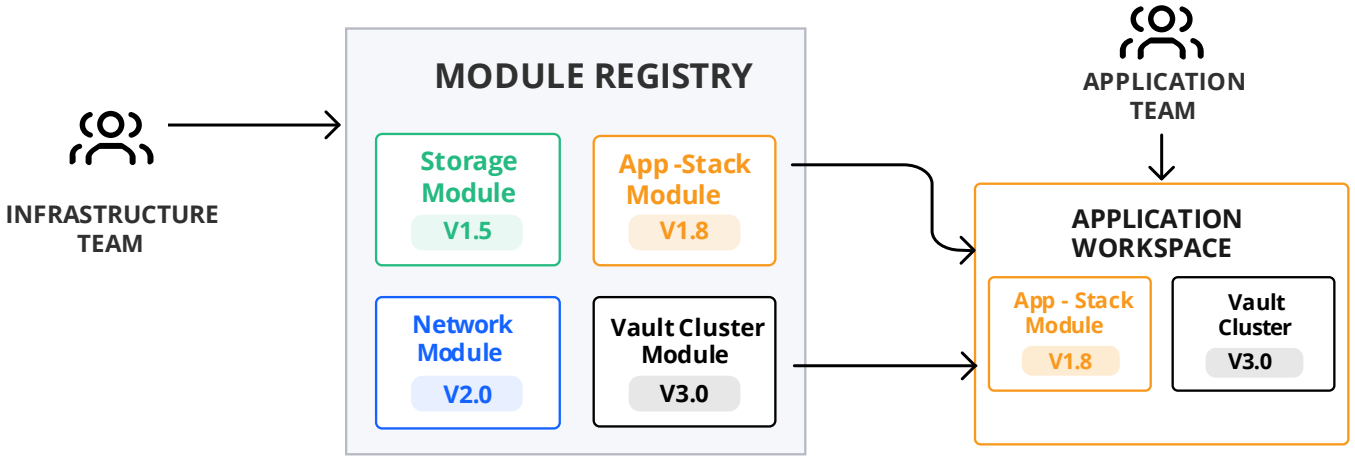


From *Webinar Recap: Unlocking the Power of Cloud Operations in Higher Education and Government*, https://kion.io/resources/webinar-recap-unlocking-the-power-of-cloud-operations-in-higher-education-and-government

Do not reinvent the wheel

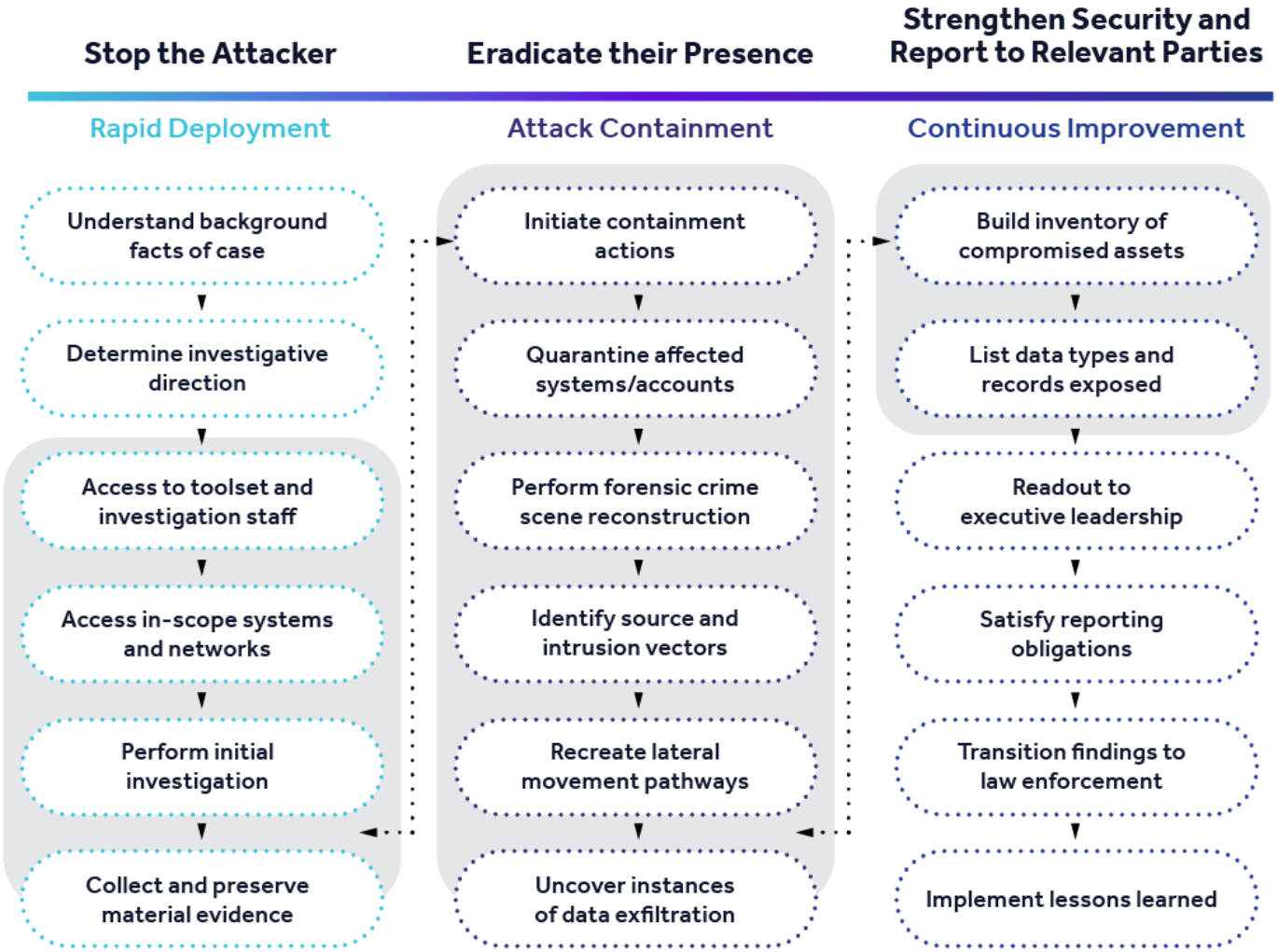
KUEHNE+NAGEL

- **Standardize libraries, processes, and tools.**





Do not panic (Think before you act)



From *What is Digital Forensics and Incident Response (DFIR)?*, https://www.esentire.com/cybersecurity-fundamentals-defined/what-is-dfir

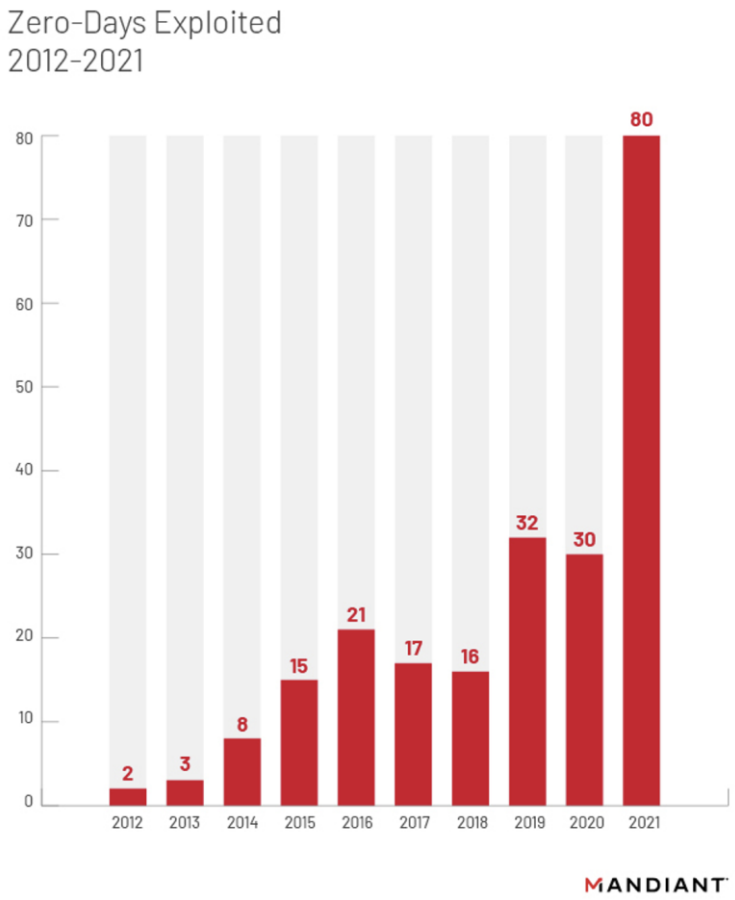
KUEHNE+NAGEL

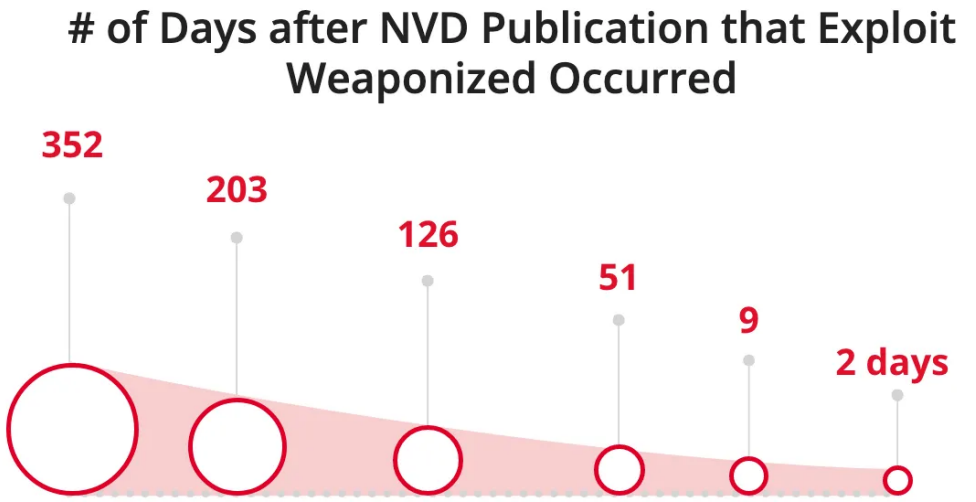
Learn from others

Tales from the Battlefield



From exploits to weaponization





2018: Exploit weaponization took 352 days

2022: Time to weaponize exploit down to 9 days

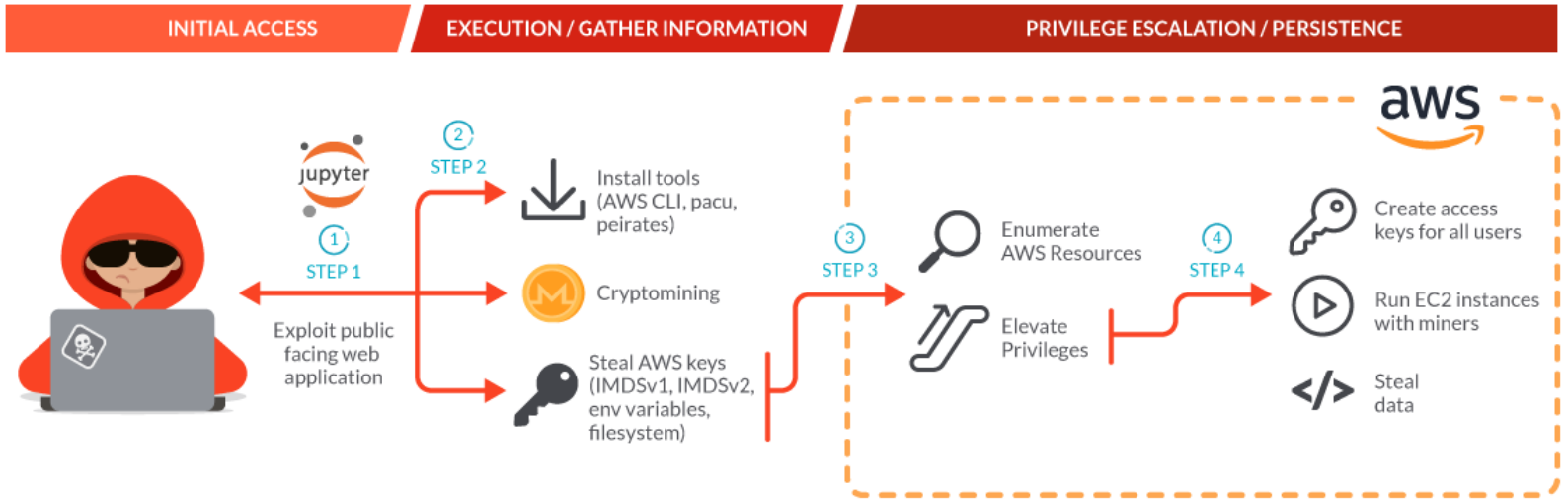
Mass exploitation of Log4Shell occurred in 48 hours

From *Zero Tolerance: More Zero-Days Exploited in 2021 Than Ever Before*, https://www.mandiant.com/resources/blog/zero-days-exploited-2021
And Why Organizations Struggle with Patch Management (and What to Do about It), https://blog.qualys.com/qualys-insights/2022/09/20/why-organizations-struggle-with-patch-management-and-what-to-do-about-it

Credential Leaks / Insecure Default Credentials

KUEHNE+NAGEL

- **2019, Samsung**, credentials leaked in exposed GitLab instance
- **2020, Cameo,** credentials in mobile app package
- **2023, CommuteAir,** publicly Exposed Jenkins with hardcoded credentials
- **2023, Unit42**, credentials exposed on Github
- **...**

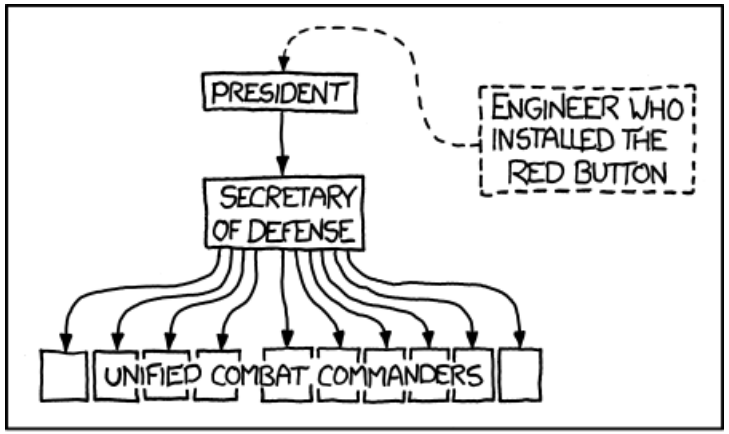


From *SCARLETEEL 2.0: Fargate, Kubernetes, and Crypto*, https://sysdig.com/blog/scarleteel-2-0/

Privilege Misconfiguration / Escalation

KUEHNE+NAGEL

- **2018, Capital One**, "Misconfigured WAF" that allowed for a SSRF attack, escalated via over-privileged EC2
- **2021**, **DarkLab case study,** Jenkins with RCE vulnerability deployed in AWS environment with a *hardcoded root access key*, created multiple IAM user accounts and accessed internal data
- **2023, Sysdig,** exploit public facing Jupyter Notebook in k8s to fetch IAM creds, including via IMDSv2 with privilege escalation via IAM misconfiguration leading to cryptojacking



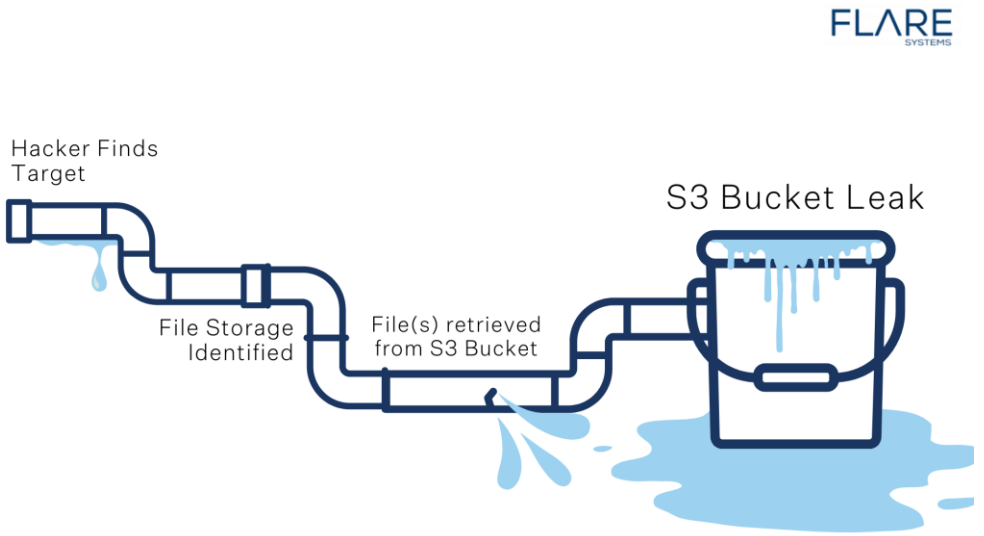
US NUCLEAR CHAIN OF COMMAND

From *xkcd*, https://xkcd.com/898/

Bucket Leaks (S3)

KUEHNE+NAGEL

- **2017, NSA,** leak exposes the Army's failed intelligence system, 100 gigabytes of data from an Army project
- **2020, Twilio,** S3 global write access
- **2021, Securitas,** exposed nearly 1.5 million files, equating to about 3TB of data
- **2023, TripValet**, Credentials in node env file in public S3 bucket
- (...) https://github.com/nagwww/s3-leaks



From *Information Leakage: What you need to Know*, https://flare.io/learn/resources/blog/information-leakage/

The Low-Hanging Fruits

Insider Threats

KUEHNE+NAGEL

- **2018, Chegg**, former contractor abuses broadly shared root credential.
- **2020, First Republic Bank,** fired employee incompletely offboarded leads to system interruption.
- **2020, Cisco**, former employee with AWS access deletes ~450 EC2.
- **2021, Ubiquiti**, compromised credentials from IT employee Lastpass.
- **2022, Uber**, contractor account. compromise leading to AWS credential discovery on a shared drive.
- **2023, Massachusetts Air National Guard,** Jack Teixeira, disseminated top secret documents online.
- …



From *What Is an Insider Threat? Definition, Types, and Countermeasures*, https://www.ekransystem.com/en/blog/insider-threat-definition;
Based on: https://www.verizon.com/business/resources/articles/s/the-risk-of-insider-threat-actors/

The (fail) trusted-link

Solorigate / SUNBURST (SolarWinds Orion)

SUPPLY CHAIN ATTACK
Attackers insert malicious code into a DLL component of legitimate software. The compromised DLL is distributed to organizations that use the related software.

EXECUTION, PERSISTENCE
When the software starts, the compromised DLL loads, and the inserted malicious code calls the function that contains the backdoor capabilities.

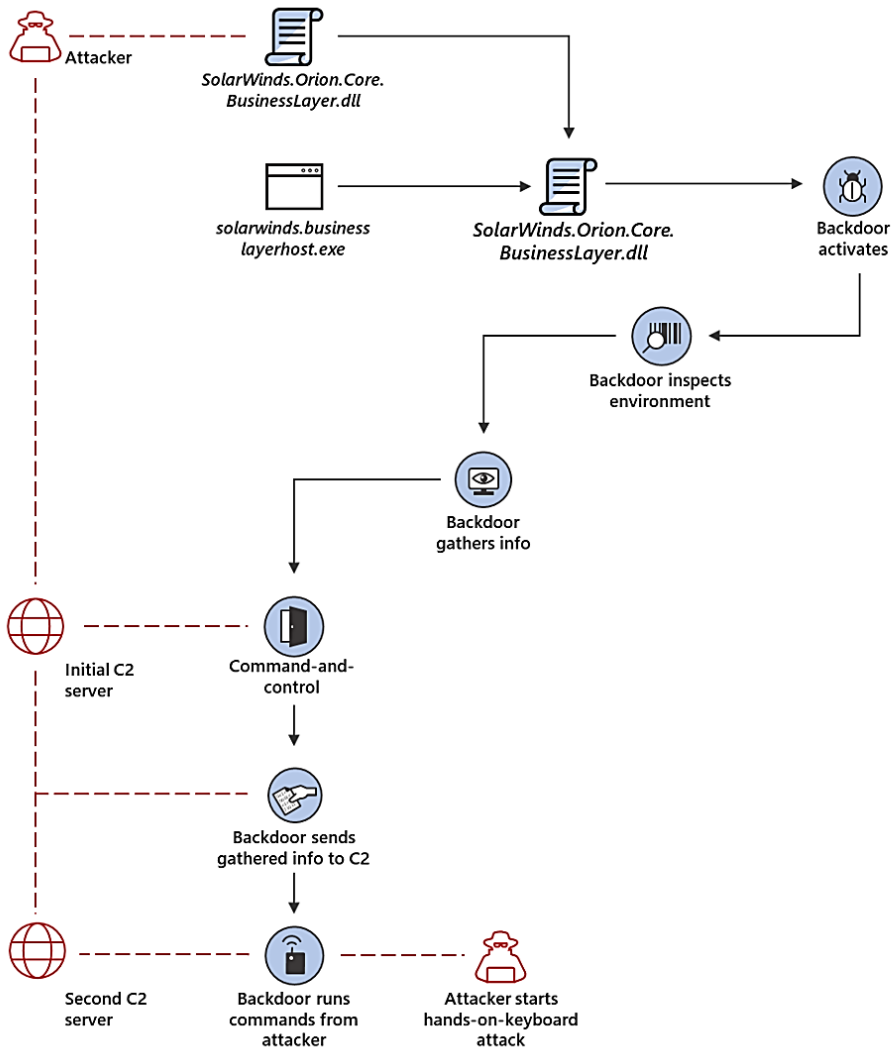
DEFENSE EVASION
The backdoor has a lengthy list of checks to make sure it's running in an actual compromised network.

RECON
The backdoor gathers system info
AV flagged it, but it was considered false positive as it was originating from a trusted software

INITIAL C2
The backdoor connects to a command-and-control server. The domain it connects to is partly based on info gathered from system, making each subdomain unique. The backdoor may receive an additional C2 address to connect to.

EXFILTRATION
The backdoor sends gathered information to the attacker.

HANDS-ON-KEYBOARD ATTACK
The backdoor runs commands it receives from attackers. The wide range of backdoor capabilities allow attackers to perform additional activities, such as credential theft, progressive privilege escalation, and lateral movement.

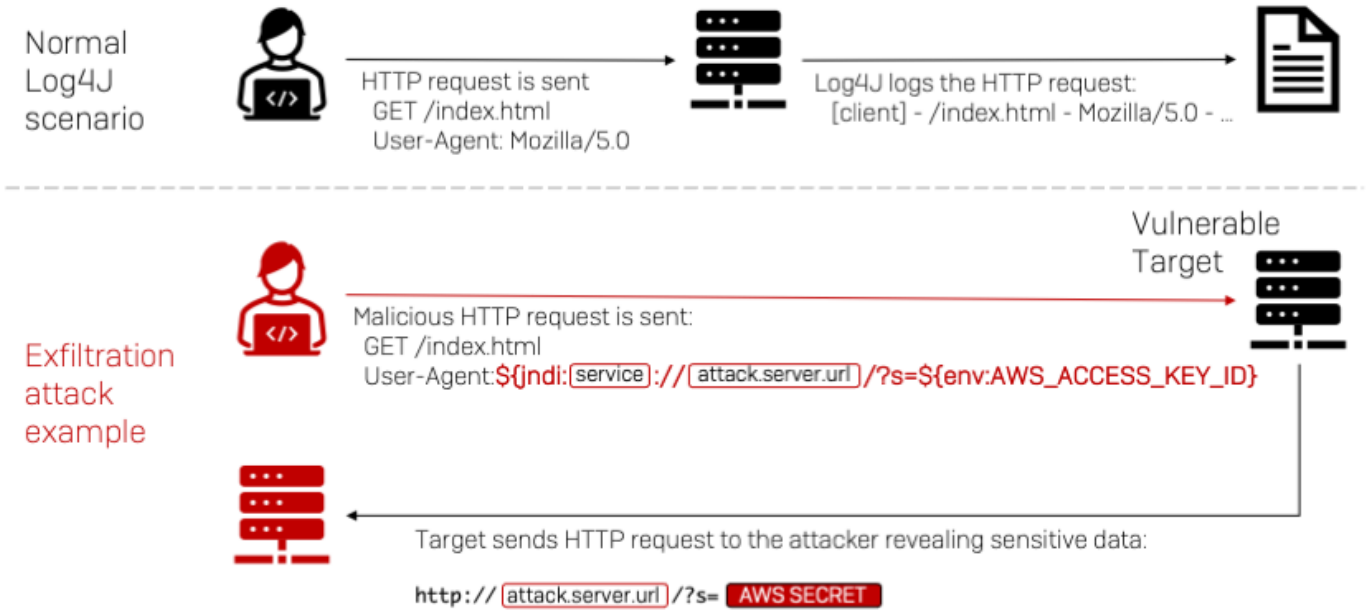


solarwinds
Sunburst

From *Analyzing Solorigate, the compromised DLL file that started a sophisticated cyberattack, and how Microsoft Defender helps protect customers*, https://www.microsoft.com/en-us/security/blog/2020/12/18/analyzing-solorigate-the-compromised-dll-file-that-started-a-sophisticated-cyberattack-and-how-microsoft-defender-helps-protect/

Log4Shell

KUEHNE+NAGEL

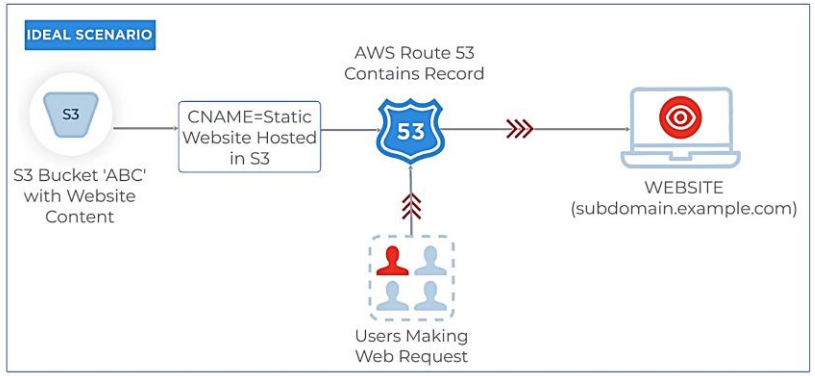


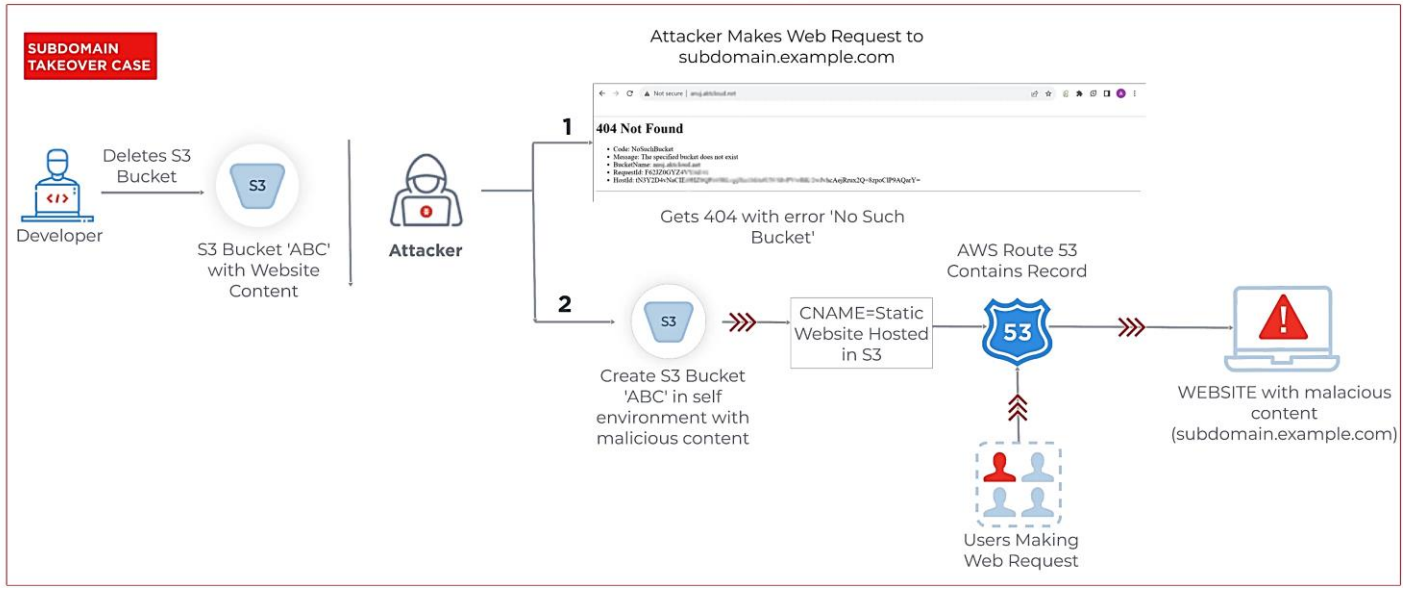


From *Log4Shell Hell: anatomy of an exploit outbreak*, https://news.sophos.com/en-us/2021/12/12/log4shell-hell-anatomy-of-an-exploit-outbreak/

The abandoned resources

Subdomain Takeover on S3 buckets





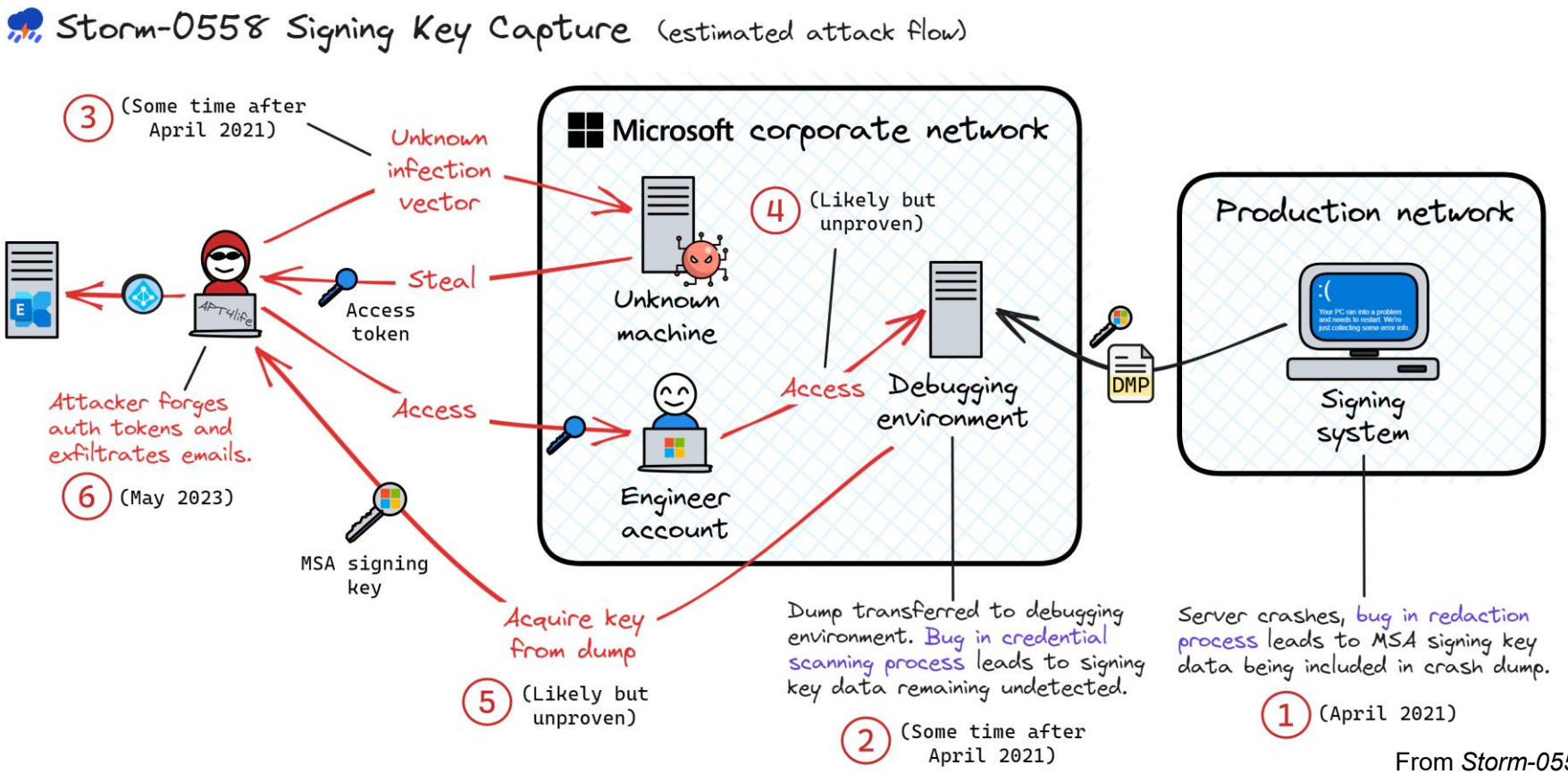
From *Subdomain Takeover via Abandoned Amazon S3 Bucket*, https://char49.com/articles/subdomain-takeover-via-abandoned-amazon-s3-bucket

From *Hijacking S3 Buckets: New Attack Technique Exploited in the Wild by Supply Chain Attackers*, https://checkmarx.com/blog/hijacking-s3-buckets-new-attack-technique-exploited-in-the-wild-by-supply-chain-attackers/

TotalCloud Insights: Crafting Effective Indicators of Compromise (IoCs) for Sub-domain Takeover Risk Detection, https://blog.qualys.com/product-tech/2024/01/11/totalcloud-insights-crafting-effective-indicators-of-compromise-iocs-for-sub-domain-takeover-risk-detection

Trust the cloud, the cloud is your friend

Losing the keys to the kingdom, aka Microsoft consumer signing key stolen



From *Storm-0558 Update: Takeaways from Microsoft's recent report*, https://www.wiz.io/blog/key-takeaways-from-microsofts-latest-storm-0558-report

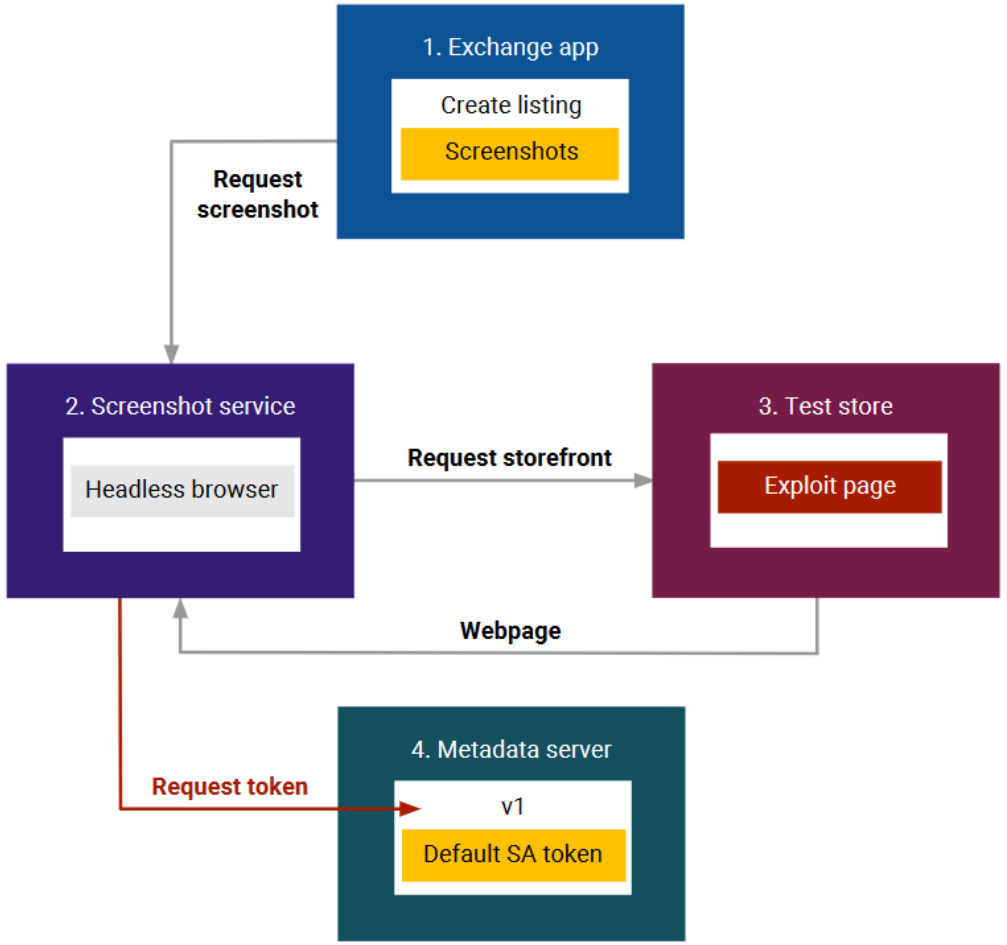
Exploit chain chaos

The 25 000$ Shopify vulnerability

KUEHNE+NAGEL

- **Server-side Request Forgery as entry-point**
- **Code injected in Shopify template**
- **Code was executed in a store preview system**
- **Retrieved secrets from environment**
  - Exfiltrate secrets from Google Cloud Meta APIs
- **Access to K8s cluster**
  - Right to execute arbitrary commands

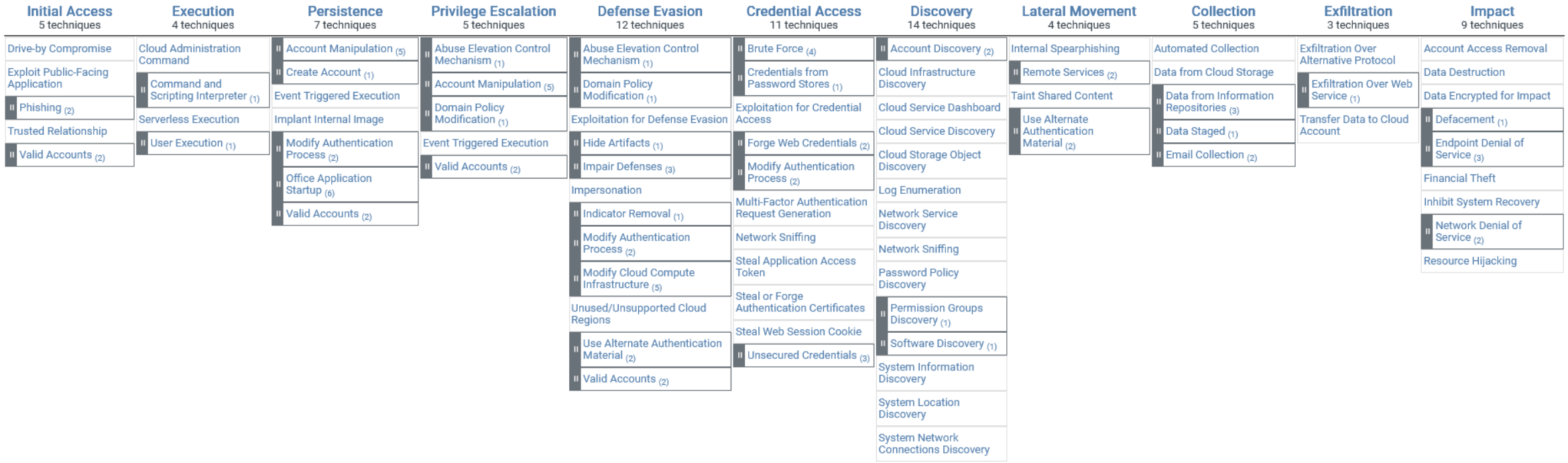
Report:
https://hackerone.com/reports/341876 by @0xacb



What’s next?

MITRE | ATT&CK

KUEHNE+NAGEL



From *MITRE ATT&CK® Matrix for Enterprise covering cloud-based techniques*,
https://attack.mitre.org/matrices/enterprise/cloud/#

Start small and prioritize



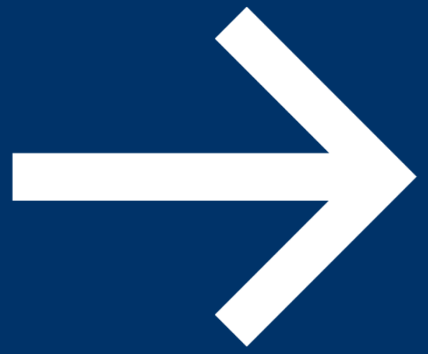
Don’t become a gatekeeper



Spread knowledge

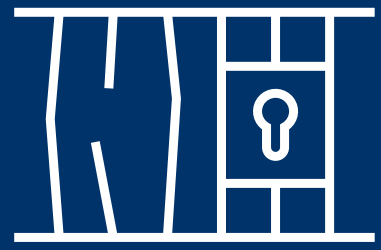


KUEHNE+NAGEL



Be a *Hacker!*

http://phrack.org/issues/7/3.html



References / Read more

KUEHNE+NAGEL

- AWS Security Maturity Roadmap, https://summitroute.com/downloads/aws_security_maturity_roadmap-Summit_Route.pdf
- 12 Steps to Cloud Security, https://speakerdeck.com/cloudronin/12-steps-to-cloud-security-1
- Beyond the Baseline: Horizons for Cloud Security Programs, https://speakerdeck.com/ramimac/beyond-the-baseline-horizons-for-cloud-security-programs
- Cloud Architecture Security Cheat Sheet, https://cheatsheetseries.owasp.org/cheatsheets/Secure_Cloud_Architecture_Cheat_Sheet.html
- Cloud Security Patterns by sirris.be, http://www.sirris.be.s3-website-eu-west-1.amazonaws.com/
- Cloud design patterns that support security, https://learn.microsoft.com/en-us/azure/well-architected/security/design-patterns
- Cloud Native Security 101: Building Blocks, Patterns and Best Practices, https://speakerdeck.com/rafik8/cloud-native-security-101-building-blocks-patterns-and-best-practices
- Learning from AWS Customer Security Incidents [2022], https://speakerdeck.com/ramimac/learning-from-aws-customer-security-incidents-2022

Inspire. Empower. Deliver.

KUEHNE+NAGEL



© 2020 Kuehne+Nagel All rights reserved